
بسم الله الرحمن الرحیم

جمهوری اسلامی ایران
وزارت آموزش و پرورش

« وَقُلِ اعْمَلُوا فَسَيَرَى اللَّهُ عَمَلَكُمْ وَرَسُولُهُ وَالْمُؤْمِنُونَ »

و [به مردم] بگو: [هر آنچه می‌خواهید] عمل کنید؛ که به زودی خدا، پیامبر او و مؤمنان اعمال شما را می‌بینند [و بر آن ناظرند].»

(سوره توبه - آیه ۱۰۵)

گزارش جامع فنی، معماری امنیتی و راهنمای عملکردی سامانه ستاد خبری و دریافت گزارش‌های مردمی حراست

اداره حراست آموزش و پرورش استان همدان

واحد حفاظت فناوری اطلاعات

طبقه بندی : محرمانه

شهریورماه ۱۴۰۵

چکیده

دریافت، ثبت و رسیدگی به گزارش های مرتبط با مفاسد اداری، تخلفات مالی، مسائل اموزشی و وقایع امنیتی در مجموعه آموزش و پرورش، نیازمند وجود بستری است که علاوه بر سهولت دسترسی برای عموم مردم و فرهنگیان، اصل «محرمانگی کامل هویت و اسناد» را تضمین کند. سامانه حاضر، پاسخی جامع، بومی و به دور از پیچیدگی های غیرضروری برای دستیابی به این هدف است. ویژگی های بنیادین و محوری این سامانه عبارتند از:

به منظور بستن کامل روزنه های نفوذ ناشی از حملات زنجیره تأمین نرم افزار، هیچ‌گونه چهارچوب آماده یا کتابخانه آماده خارجی در لایه رابط کاربری و پردازش سرور به کار گرفته نشده و هسته پردازشی به صورت خالص و سرراست پیاده سازی شده است.

متن گزارش ها، اطلاعات هویتی افراد، مکاتبات تکمیلی، یادداشت های محرمانه کارشناسان و فایل های ارسالی با استاندارد رمزنگاری متقارن احرازشده[1] کد گذاری گردیده و در پایگاه داده ذخیره می شوند.

گزارش های رویداد نگاری سیستم با بهره گیری از محرک های پایگاه داده در سطح دسترسی غیرقابل ویرایش و حذف نگهداری می‌شوند تا امکان هرگونه امحای ردپای اداری یا دستکاری سیستمی سلب گردد.

[1] AES-256-GCM

فهرست مطالب

چکیده ——— ۳

تبیین مسأله، معماری کلان و انتخاب پشته فناوری ——— ۵

۱.۱ پیش زمینه و اهداف امنیتی راه اندازی درگاه دریافت گزارش ها ——— ۵

۱.۲ تحلیل ریسک و دلایل حذف وابستگی‌ها و چارچوب‌های خارجی ——— ۵

۱.۳ مشخصات هسته مرکزی سرور و لایه پردازش ——— ۶

۱.۴ پایگاه داده، الگو های ذخیره سازی و پایش نشست ها ——— ۶

مهندسی لایه عمومی و تجربه کاربری مراجعان ——— ۷

۲.۱ فرآیند سه مرحله ای ثبت گزارش و بازیابی پیش نویس محلی ——— ۷

۲.۲ سیستم بررسی امنیتی فایل های پیوست و مهار فایل های مخرب ——— ۱۰

۲.۳ سیستم پیگیری گزارش و گفتگوی دوطرفه امن ——— ۱۱

کارتابل جامع و پنل مدیریت حراست ——— ۱۲

۳.۱ داشبورد مانیتورینگ، شاخص های عملکردی و تریاژ پرونده ها ——— ۱۳

۳.۲ ابزار ثبت یادداشت های محرمانه داخلی و صدور پرونده رسمی در قالب Word ——— ۱۴

۳.۴ مدیریت کاربران اداری، چرخش اجباری رمز عبور و قطع دسترسی بلادرنگ ——— ۱۷

پیاده سازی سازوکارهای امنیتی و تطابق با الزامات افتا ——— ۱۹

۴.۱ رمزنگاری متقارن احراز اصالت شده با AES-256-GCM ——— ۱۹

۴.۲ اعتبارسنجی پیچیدگی و هش سازی کلمات عبور با الگوریتم Argon2id ——— ۲۰

۴.۳ سیستم تصویر امنیتی (کپچا) محاسباتی بدون حالت ——— ۲۲

۴.۴ مدیریت نشست های کاری، کنترل نرخ درخواست و قفل حساب ——— ۲۲

۴.۵ لاگ های بازرسی تغییرناپذیر پایگاه داده (قاعده WORM) و هدرهای امنیتی ——— ۲۴

ساختار جداول پایگاه داده و روابط موجودیت ها ——— ۲۴

راهنمای راه اندازی، متغیرهای محیطی و استقرار سیستمی ——— ۲۶

۶.۱ پیش نیازهای سخت افزاری و نرم افزاری سرور ——— ۲۶

۶.۲ جدول متغیرهای محیطی سیستم ——— ۲۶

۶.۳ مراحل گام به گام استقرار و راه اندازی در لینوکس ——— ۲۷

۶.۴ دستورالعمل تهیه پشتیبان و نگهداری دوره‌ای ——— ۲۹

تبیین مسأله، معماری کلان و انتخاب پشته فناوری

۱.۱ پیش زمینه و اهداف امنیتی راه اندازی درگاه دریافت گزارش ها

سامانه‌های ستاد خبری در ساختار حراست آموزش و پرورش، به دلیل حساسیت داده ها در رده سامانه های با ضریب حفاظت بالا طبقه بندی می شوند. هر گونه نشت اطلاعات، افشای هویت گزارش دهندگان، یا دستکاری لاگ های بررسی تخلفات، می‌تواند آسیب های جبران ناپذیری به اعتماد عمومی و سلامت اداری وارد سازد.

اهداف بنیادین مد نظر در پیاده سازی این سامانه عبارتند از:

- ✓ **ایجاد کانال ارتباطی مطمئن و ناشناس برای ارسال گزارش تخلفات بدون نیاز به ارائه هویت.**
- ✓ **ممانعت از ذخیره سازی داده های حساس به صورت متن خام[۲] در پایگاه داده.**
- ✓ **ثبت دقیق و غیرقابل دستکاری کلیه اقدامات اداری به همراه آدرس شبکه و زمان دقیق وقوع.**

۱.۲ تحلیل ریسک و دلایل حذف وابستگی‌ها و چارچوب‌های خارجی

در اکثر پروژه های تحت وب امروری، استفاده از چارچوب های سنگین و وابستگی به هزاران بسته نرم افزاری کوچک امری متداول است. اما در سامانه های حراستی و امنیتی، این رویکرد خطرات بزرگی در بر دارد:

حملات زنجیره تأمین[۳]: کتابخانه های شخص ثالث ممکن است در طول زمان هک شده، دستکاری شوند یا کدهای مخرب درون آن ها تزریق گردد. حذف کامل این وابستگی ها، سطح حمله سامانه را به حداقل ممکن می‌رساند. پایداری، استقلال و ماندگاری سامانه: کد های خالص مبتنی بر استاندارد های بومی وب[٤] و زبان برنامه نویسی Go تا سال ها بدون نیاز به بروزرسانی های مداوم یا شکست وابستگی ها، عملکرد روان و یکپارچه خود را حفظ می کنند. سبک بودن و سرعت بالای بارگذاری: حجم کل کد های برنامه در لایه فرانت و و بک

---

[۲] Plaintext

[۳] Supply Chain Attacks

[٤] HTML5, Modern CSS, Vanilla JS

به قدری کم حجم است که در شرایط شبکه ضعیف یا سامانه های داخلی نیز در کسری از ثانیه بارگزاری و اجرا می‌شوذ.

۱.۳ مشخصات هسته مرکزی سرور و لایه پردازش

لایه بک‌اند با استفاده از زبان کامپایلری Go (نسخه ۱.۲۶) توسعه یافته است. دلایل فنی انتخاب زبان Go برای این پروژه عبارتند از:

- ✓ خروجی باینری واحد[۵]: سامانه بدون نیاز به نصب هیچگونه مفسر یا پیش نیاز نرم افزاری، به صورت یک فایل اجرایی مستقل اجرا شده و انتقال و استقرار آن روی سرور های لینوکس یا ویندوز بسیار آسان است.
- ✓ کارایی بالا در پردازش همزمان[۶]: استفاده از روال های سبک Go امکان پاسخگویی به صدها درخواست همزمان، پردازش بلادرنگ رمز نگاری فایل ها و مدیریت تایمر های انقضای نشست ها را با کمترین مصرف حافظه فراهم می‌سازد.
- ✓ بهره گیری از کتابخانه استاندارد: مدیریت مسیر های وب، خواندن اطلاعات ارسالی، کنترل محدودیت حجم و ارتباطات شبکه مستقیما توسط پکیج پیش فرض net/http صورت می گیرد و نیازی به چارچوب های جانبی وب وجود ندارد.

۱.۴ پایگاه داده، الگو های ذخیره سازی و پایش نشست ها

پایگاه داده سامانه از نوع رابطه ای قدرتمند PostgreSQL انتخاب شده است. لایه اتصال پایگاه داده از درایور بومی lib/pq با تنظیمات سخت گیرانه استخر اتصالات[۷] استفاده می‌کند:

- ✓ حداکثر ۲۵ اتصال همزمان باز
- ✓ نگهداری ۵ اتصال آماده به کار

---

۵ Single Binary

۶ Goroutines

۷ Connection Pooling

- ✓ **انقضای اتصالات بدون استفاده در بازه ۲ دقیقه و بازنشانی کامل در بازه ۵ دقیقه جهت آزادسازی منابع سرور.**

علاوه بر پایگاه داده، سامانه دارای یک مدیر نشست های درون حافظه ای[۸] امن و همگام سازی شده بر مبنای قفل های خواندن/نوشتن[۹] است که تمامی فعالیت های مدیران را به صورت لحظه ای رصد کرده و نشست های منقضی شده را طی فرآیند های پس زمینه خودکار[۱۰] پاکسازی می نماید.

مهندسی لایه عمومی و تجربه کاربری مراجعان

۲.۱ فرآیند سه مرحله ای ثبت گزارش و بازیابی پیش نویس محلی

برای اینکه کاربر هنگام ورود اطلاعات خسته یا سردرگم نشود، فرم ثبت گزارش به سه مرحله مجزا و گام به گام تقسیم شده است:

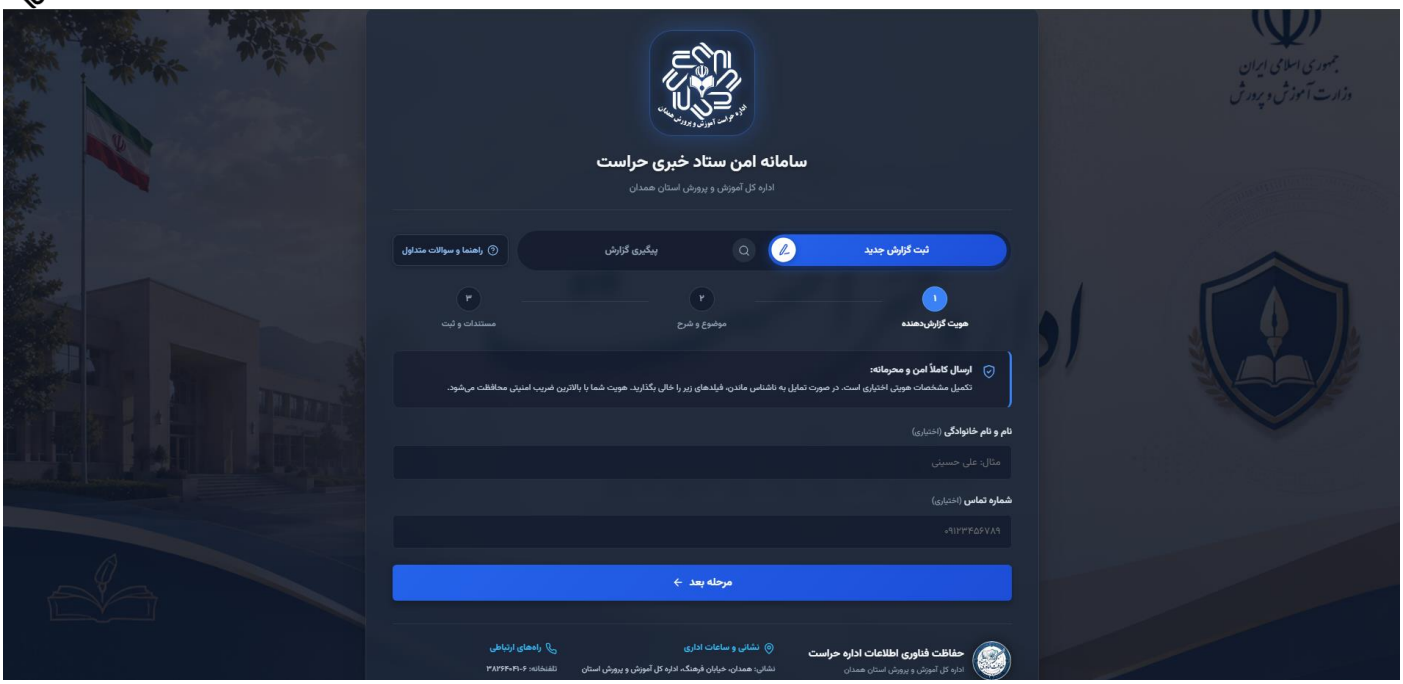
مرحله اول مشخصات هویت (اختیاری): کاربر در صورت تمایل می تواند نام و شماره تماس خود را بنویسد یا اینکه فیلدها را خالی بگذارد. اگر فیلدها خالی بمانند، سامانه نوع گزارش را به صورت خودکار «ناشناس» ثبت می کند و هیچ ردی از هویت شخص ذخیره نمی شود.

---

[۸] In-Memory Session Manager

[۹] sync.RWMutex

[۱۰] Reaper Goroutine



مرحله دوم انتخاب موضوع و متن گزارش:دسته بندی موضوعات، ۱۰ موضوع اداری و آموزشی مشخص شده است (تخلفات مالی، مسائل امنیتی، تخلفات اداری، تخلفات آموزشی، پرسنلی، دانش آموزی، مدارس غیردولتی، آموزش مجازی، فضای مجازی و سایر) که ممکن است بسته به شرایط در آینده تغییر کند.

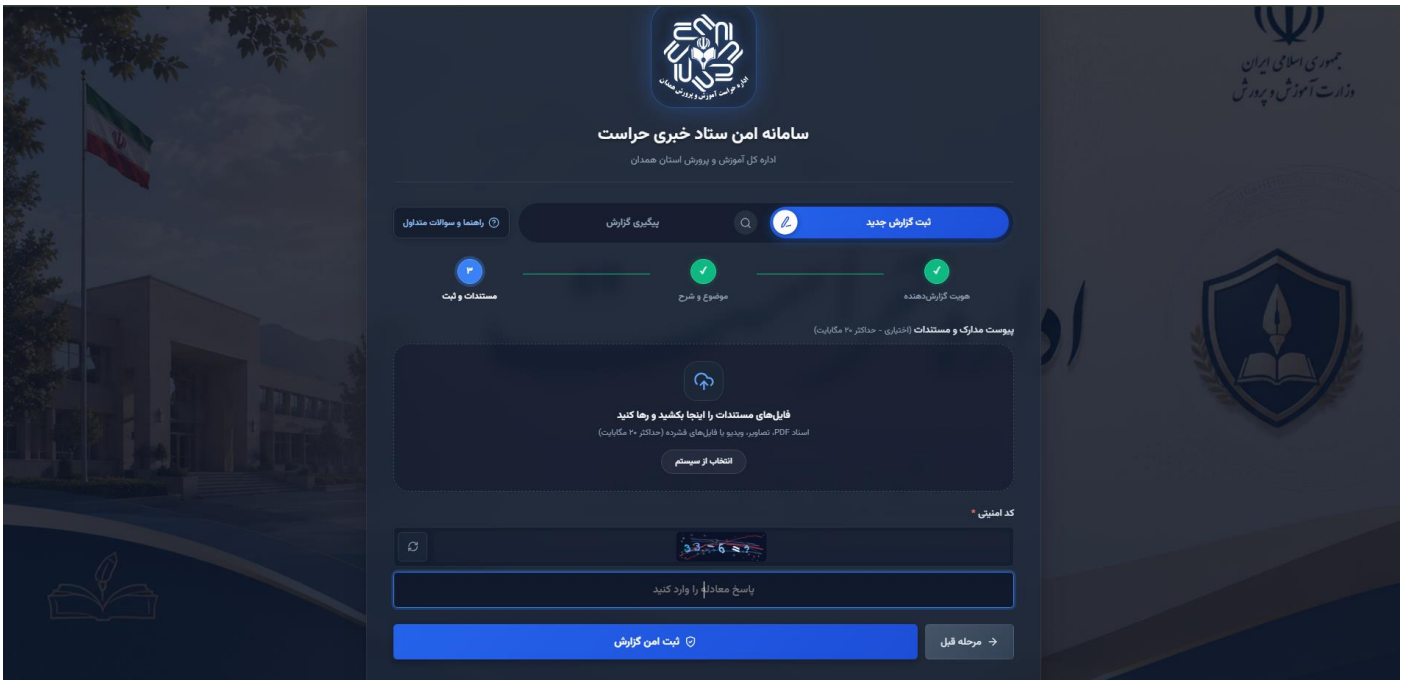
کادر شرح گزارش و متن گزارش تا ۵۰۰۰ کاراکتر جا دارد. کادر متن متناسب با تایپ کاربر بزرگ می شود[۱۱] و شمارنده تعداد حروف نیز به محض نزدیک شدن به سقف مجاز، رنگش عوض می شود تا کاربر متوجه شود.



[۱۱] Auto-expand

مرحله سوم پیوست مدارک، کد امنیتی و ثبت نهایی:

- ✓ **امکان ارسال فایل های مستند تا سقف ۲۰ مگابایت.**
- ✓ **حل معادله ساده تصویر امنیتی[۱۲].**
- ✓ **پنجره بررسی نهایی: قبل از ارسال نهایی، یک کادر باز می شود و خلاصه موضوع، بخشی از متن و نام فایل پیوست را نشان می دهد تا کاربر یک بار دیگر همه چیز را چک کند و بعد دکمه تایید را بزند.**



سیستم ذخیره و بازیابی پیش نویس[۱۳]

اگر وسط نوشتن گزارش، برق برود یا صفحه مرورگر بسته شود، اطلاعات کاربر از بین نمی رود. متن گزارش و موضوع انتخاب شده بصورت خودکار و با فاصله ۱.۵ ثانیه بعد از تایپ، داخل حافظه موقت مرورگر[۱۴] ذخیره می شود. با باز کردن مجدد صفحه، فرم خودش پر می شود و پیامی مبنی بر بازیابی پیش نویس نشان می دهد. وقتی گزارش با موفقیت ثبت نهایی شد، این حافظه موقت به صورت کامل پاک می گردد.

---

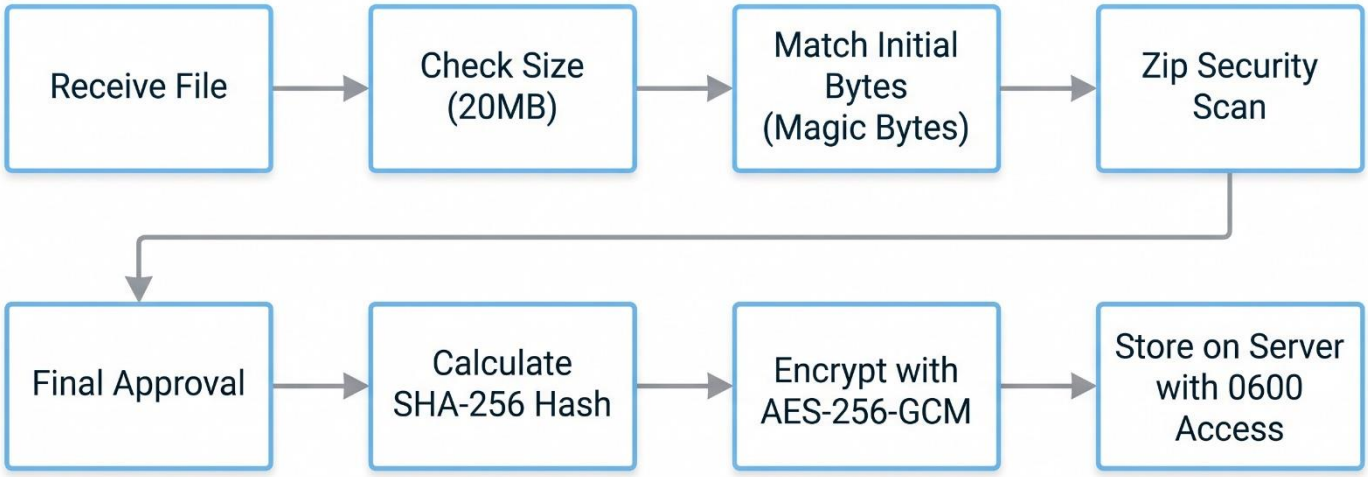
[۱۲] Captcha

[۱۳] Draft Recovery

[۱۴] sessionStorage

۲.۲ سیستم بررسی امنیتی فایل های پیوست و مهار فایل های مخرب

بخش دریافت فایل همیشه خطرناک ترین قسمت یک سامانه وب است. برای جلوگیری از ارسال کدهای مخرب یا فایل های آلوده، چند مرحله بررسی سخت گیرانه در لایه سرور پیاده شده است:



به ترتیب فرآیند دریافت و ذخیره فایل عبارت است از :

۱ دریافت فایل.

۲ بررسی حجم فایل که زیر ۲۰ مگابایت باشد.

۳ اعتبار سنجی امضای هدر فایل برای جلوگیری از جعل پسوند و اجرای کد های نامعتبر.

۴ بازرسی محتوای فایل های فشرده برای مقابله با بدافزار ها و حملات تخریبی .

۵ صدور مجوز ورود فایل به فاز ذخیره سازی پس از موفقیت آمیز بودن تمام آزمون های امنیتی.

۶ تولید اثر انگشت دیجیتال فایل جهت تضمین یکپارچگی داده ها و ردیابی عدم تعییر در اینده.

۷ رمزگذاری استاندارد محتوای فایل جهت حفظ محرمانگی و اصالت داده در حالت سکون.

۸ ثبت فایل روی دیسک با محدود ترین سطح دسترسی سیستم عامل (۰۶۰۰)

مسدود کردن پسوند های خطرناک :وجود فایل های اجرایی یا اسکریپت داخل فایل فشرده (مثل exe، bat، cmd ، ps1، sh، vbs، js، msi،dll) باعث رد شدن فوری کل فایل می شود.

۲.۳ سیستم پیگیری گزارش و گفتگوی دوطرفه امن

کد پیگیری ۱۶ رقمی: این کد با استفاده از تابع تصادفی امن سیستم عامل[۱۵] تولید می شود. برای اینکه کاربر هنگام خواندن یا یادداشت کردن کد اشتباه نکند، حروفی که شبیه به هم هستند (مثل عدد ۰ و حرف O، یا عدد ۱ و حرف I) از لیست کاراکترهای تولید کد حذف شده اند. دکمه جای گذاری سریع[۱۶]: در صفحه پیگیری، دکمه ای تعبیه شده که با کلیک روی آن، کد رهگیری از حافظه کلیپ بورد مستقیما داخل کادر قرار می گیرد. مشاهده پاسخ حراست: کاربر بعد از وارد کردن کد و حل کپچا، می تواند وضعیت پرونده (در نوبت بررسی یا بررسی شده) و پاسخ کارشناس حراست را مشاهده کند. سیستم گفتگوی دوطرفه و ارسال توضیحات تکمیلی:اگر کارشناس حراست مدارک بیشتری بخواهد یا کاربر بخواهد توضیحی اضافه کند، می تواند در پایین همان صفحه پیگیری، پیام تکمیلی بفرستد. تمام این پیام ها بصورت رمزنگاری شده با AES-256-GCM در پایگاه داده ثبت می شوند. به محض ارسال پیام از طرف کاربر، یک اعلان جدید در کارتابل حراست ایجاد می شود تا کارشناس مربوطه فورا از دریافت پیام باخبر شود.

تصویر زیر قسمت مکالمه دو طرفه در پنل مدیریت را نمایش می دهد:

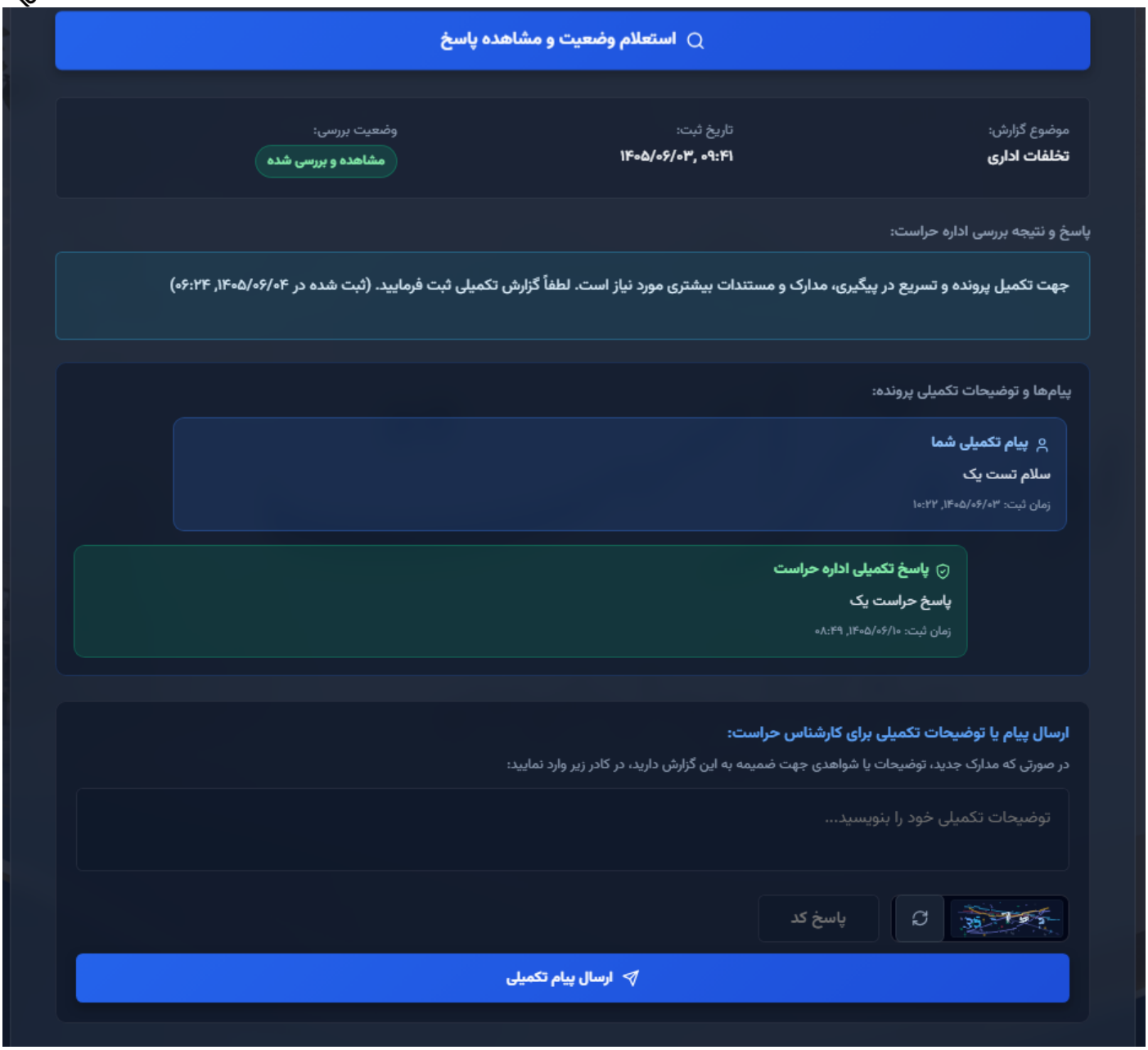


تصویر زیر قسمت پیگیری گزارش است که در اینجا نیز گزارش دهنده با استفاده از کد پیگیری ۱۶ رقمی، می تواند از پیام حراست و روند پیگیری خبر مطلع شود و به مکالمه رمز نگاری شده با کارشناس حراست بپردازد.

---

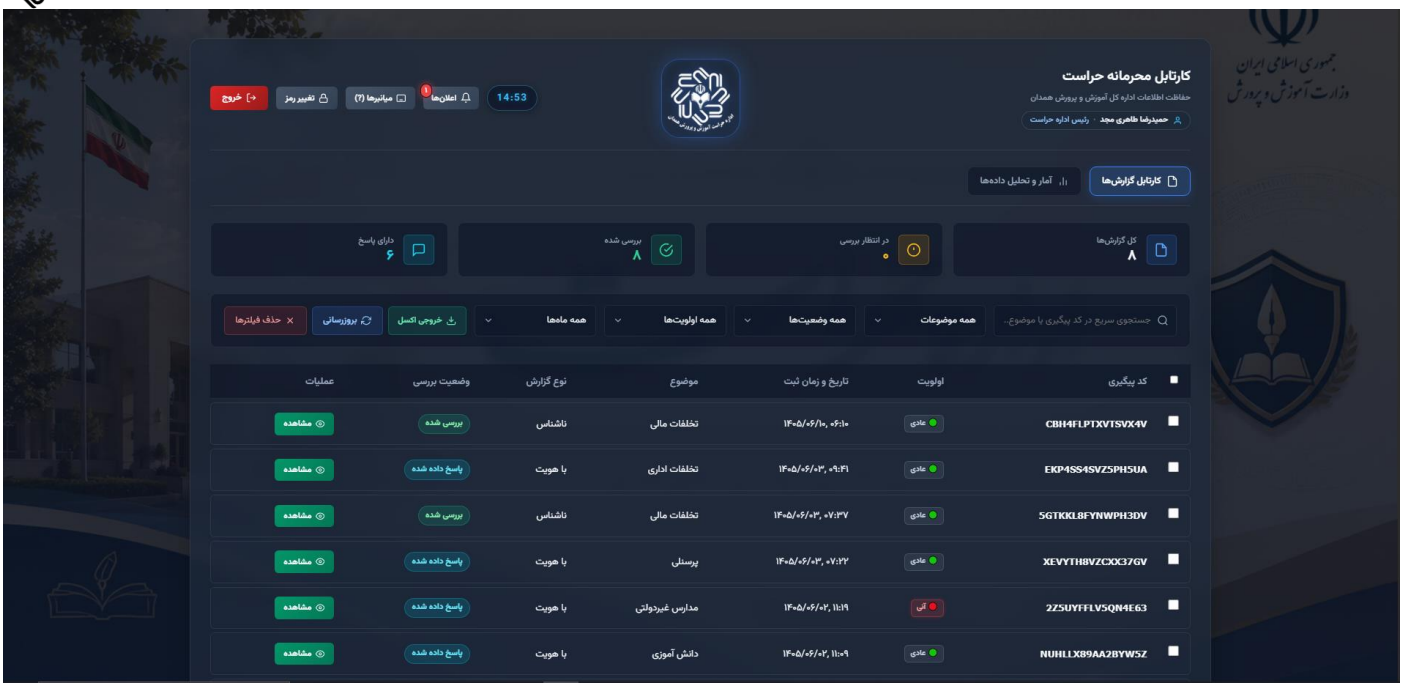
[۱۵] crypto/rand

[۱۶] Paste



کارتابل جامع و پنل مدیریت حراست

کارتابل مدیریت حراست، هسته مرکزی رسیدگی، بررسی، پاسخ دهی و تحلیل آماری گزارش های واصله است . این بخش با تفکیک دقیق سطوح دسترسی، برای دو گروه «کارشناسان بررسی کننده» و «مدیر ارشد فناوری اطلاعات» طراحی شده تا امنیت پرونده ها و روند رسیدگی به آنها در بالاترین سطح ممکن تضمین شود



۳.۱ داشبورد مانیتورینگ، شاخص های عملکردی و تریاژ پرونده ها

به محض ورود کارشناس یا مدیر به سامانه، وضعیت کلی پرونده ها در قالب کارت های شاخص کلیدی عملکرد[۱۷] در بالای صفحه نمایش داده می شود:

کارت های آماری وضعیت: نمایش تعداد کل گزارش ها، موارد در نوبت بررسی (با نشانگر چشمک زن قرمز)، گزارش های بررسی شده و پرونده های دارای پاسخ رسمی. با کلیک روی هر کارت، جدول گزارش ها فورا بر اساس همان وضعیت فیلتر می شود.

سیستم فیلتر و جستجوی پیشرفته:

- ✓ **جستجوی سریع و لحظه ای در کد پیگیری، موضوع یا متن گزارش با روشن کردن (Highlight) کلمات جستجو شده در جدول.**
- ✓ **فیلتر بر اساس ۱۰ دسته بندی موضوعی، وضعیت بررسی و ماه های سال شمسی (از فروردین تا اسفند).**
- ✓ **فیلتر اولویت بندی پرونده ها در سه سطح «عادی»، «فوری» و «آنی و ویژه» که در جدول با رنگ بندی سبز، زرد و قرمز مشخص می شوند.**

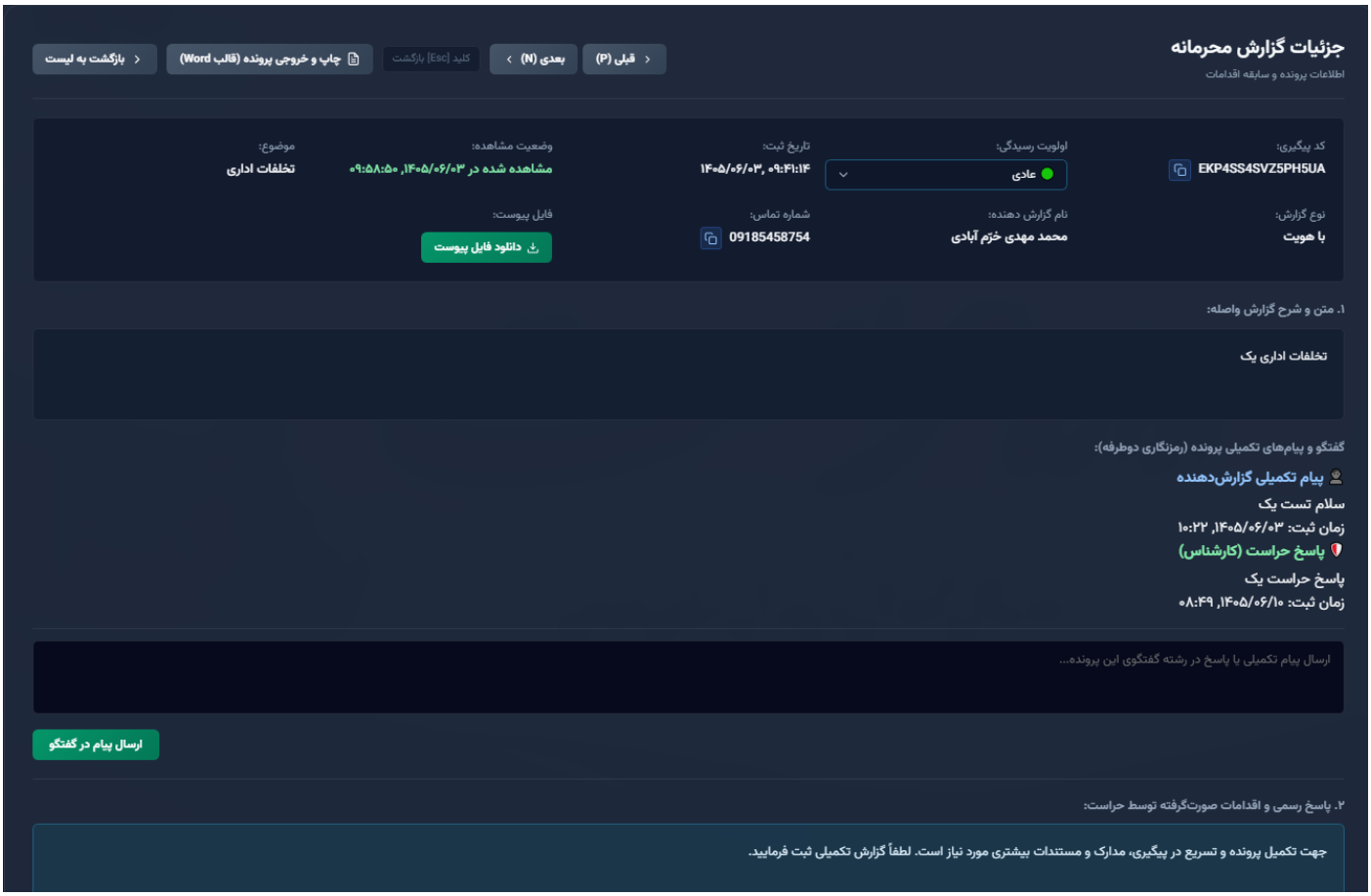
---

[۱۷] KPI

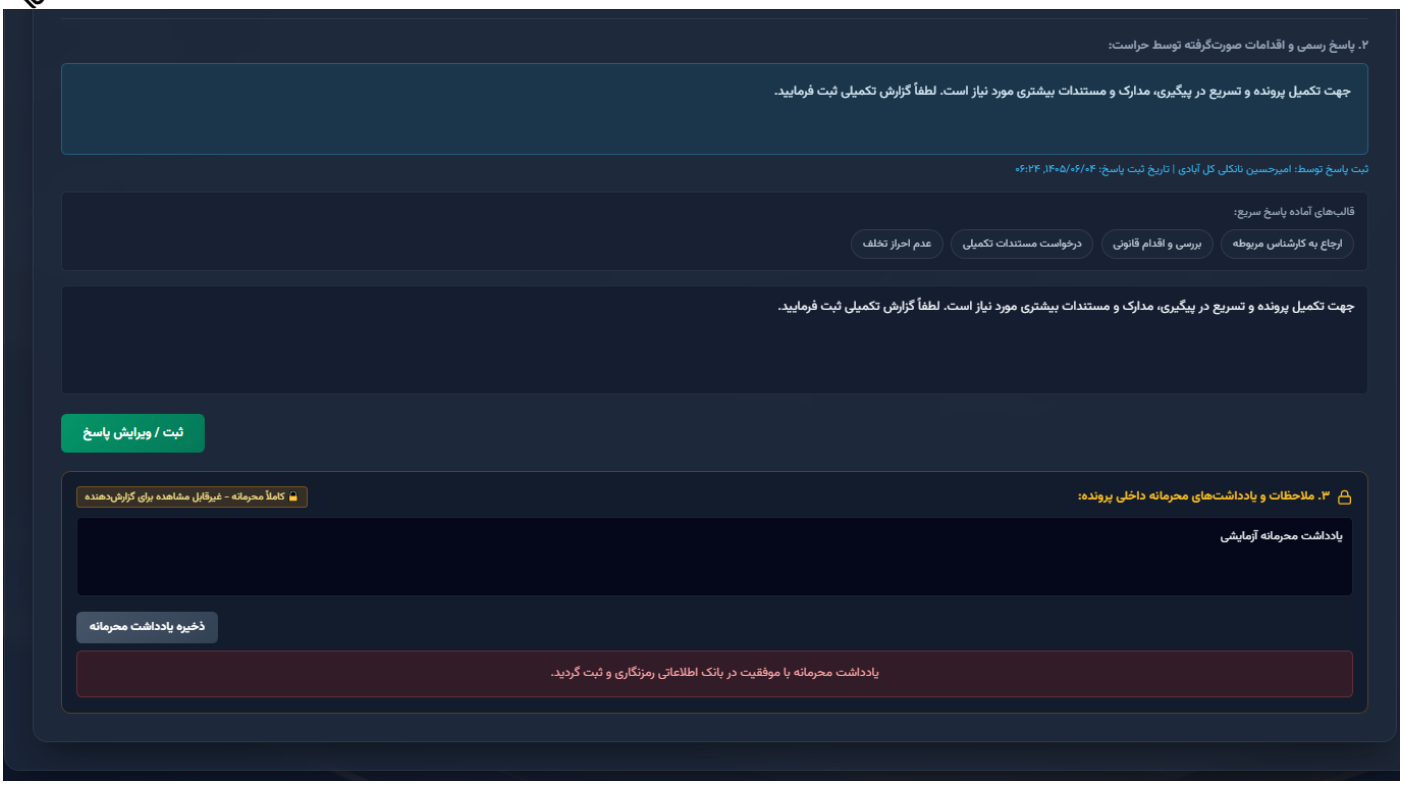
خروجی اکسل و CSV: امکان دانلود خروجی جدول گزارش های فیلتر شده در قالب فایل اکسل با فونت و کدگذاری استاندارد فارسی[۱۸].

۳.۲ ابزار ثبت یادداشت های محرمانه داخلی و صدور پرونده رسمی در قالب Word

هنگام باز کردن یک پرونده، جزئیات کامل گزارش به همراه نام و شماره تماس گزارش دهنده (در صورت وجود) از حالت رمزنگاری خارج شده و نمایش داده می شود.



[۱۸] UTF-8 BOM



یادداشت های محرمانه داخلی پرونده: کارشناسان حراست می توانند روند بررسی های میدانی، استعلامات و شماره نامه های اداری را در بخش یادداشت های محرمانه ثبت کنند. این یادداشت ها با الگوریتم AES-256-GCM رمز شده و تنها برای پرسنل حراست قابل مشاهده است و گزارش دهنده به هیچ وجه به آن دسترسی ندارد.

قالب های آماده پاسخ سریع[۱۹]: دکمه های آماده ای برای درج متون متداول (نظیر ارجاع به کارشناس، درخواست مدارک تکمیلی و عدم احراز تخلف) قرار داده شده تا سرعت پاسخ دهی بالا برود.

صدور برگ پرونده رسمی با قالب Word اختصاصی:

با زدن دکمه چاپ و خروجی پرونده، سرور اطلاعات پرونده را به صورت امن جمع اوری کرده و با اجرای کد نوشته پایتون، اطلاعات را درون قالب رسمی ورد که مخصوص اداره حراست آ.پ همدان طراحی شده است،جای گذاری می کند.

در ادامه فایل استخراج شده ورد از یک گزارش به حضورتان تقدیم می گردد.

---

[۱۹] Canned Responses

« بسمه تعالی »

برگ پرونده گزارش محرمانه

سامانه ستاد خبری و گزارش‌های مردمی

شماره پرونده: EKP4SS4SVZ5PH5UA
تاریخ ثبت: ۰۹:۴۱ - ۱۴۰۵/۰۶/۰۳
زمان چاپ: ۰۹:۰۲ - ۱۴۰۵/۰۶/۱۰
طبقه‌بندی: محرمانه

موضوع گزارش:	تخلفات اداری	**اولویت رسیدگی:**	عادی
نوع گزارش:	با هویت	**مشخصات گزارش‌دهنده:**	محمد مهدی خرّم آبادی (۰۹۱۸۵۴۵۸۷۵۴)
مستندات پیوست:	دارای فایل پیوست (۱ مورد)	**وضعیت بررسی پرونده:**	بررسی شده در ۰۹:۵۸ - ۱۴۰۵/۰۶/۰۳

۱. متن و شرح گزارش واصله:

تخلفات اداری یک

۲. پاسخ رسمی و اقدامات صورت‌گرفته توسط حراست:

جهت تکمیل پرونده و تسریع در پیگیری، مدارک و مستندات بیشتری مورد نیاز است. لطفاً گزارش تکمیلی ثبت فرمایید.

ثبت پاسخ توسط: امیرحسین نانکلی کل آبادی | تاریخ ثبت پاسخ: ۰۶:۲۴ - ۱۴۰۵/۰۶/۰۴

۳. ملاحظات و یادداشت‌های محرمانه داخلی پرونده:

یادداشت محرمانه آزمایشی

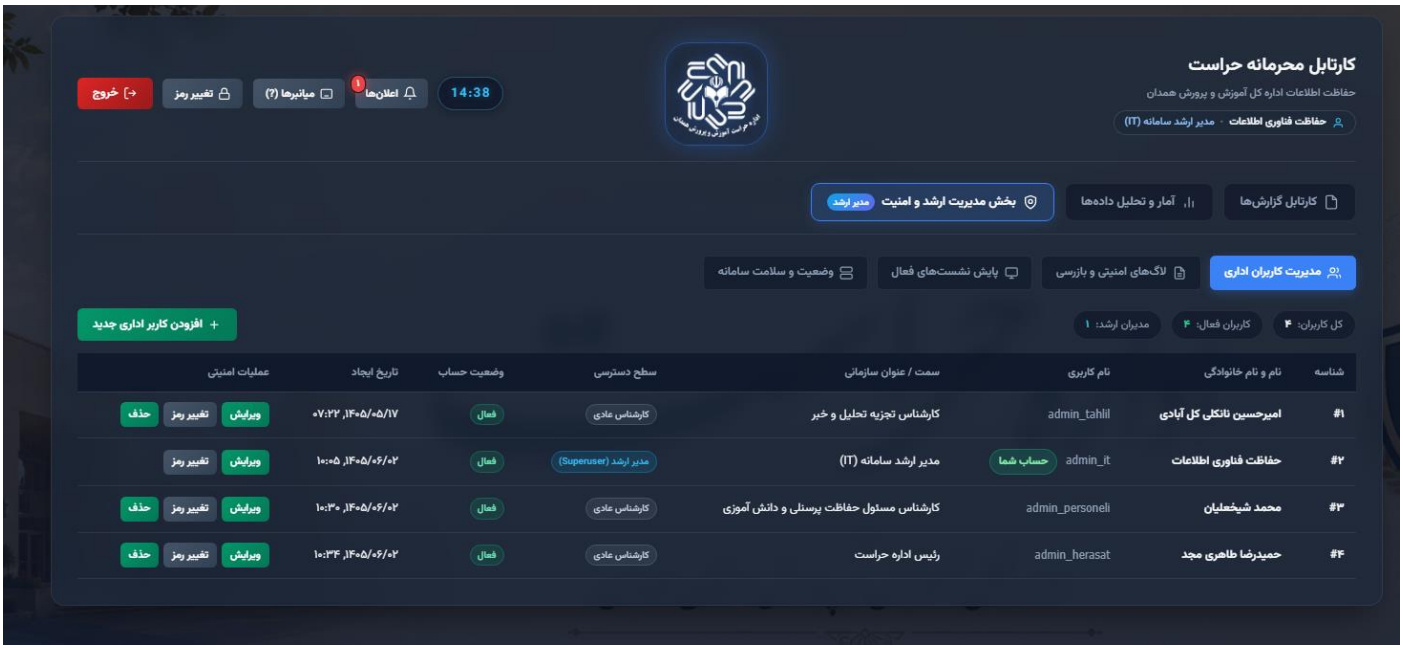
۴. صورت‌جلسه و تأییدیه نهایی بررسی پرونده:

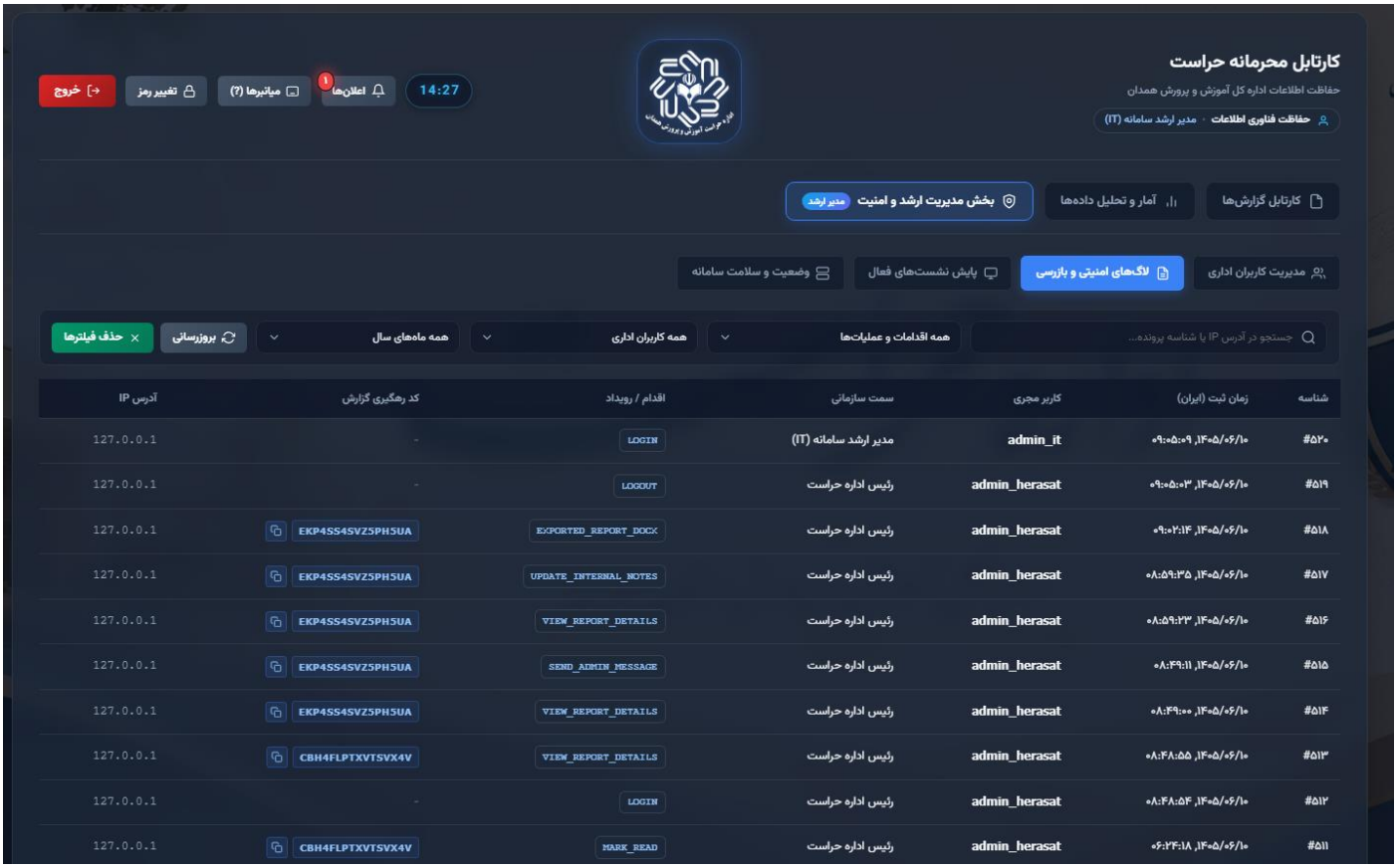
کارشناس بررسی‌کننده پرونده	رئیس / مدیر اداره حراست
نام و سمت سازمانی:	نام و سمت سازمانی: .....
محل امضاء و تاریخ	محل امضاء و تاریخ

⚠ هشدار امنیتی: این سند حاوی اطلاعات طبقه‌بندی‌شده و محرمانه اداری است. هرگونه نسخه‌برداری غیرمجاز یا افشای مفاد آن پیگرد قانونی به همراه

۳.۴ مدیریت کاربران اداری، چرخش اجباری رمز عبور و قطع دسترسی بلادرنگ

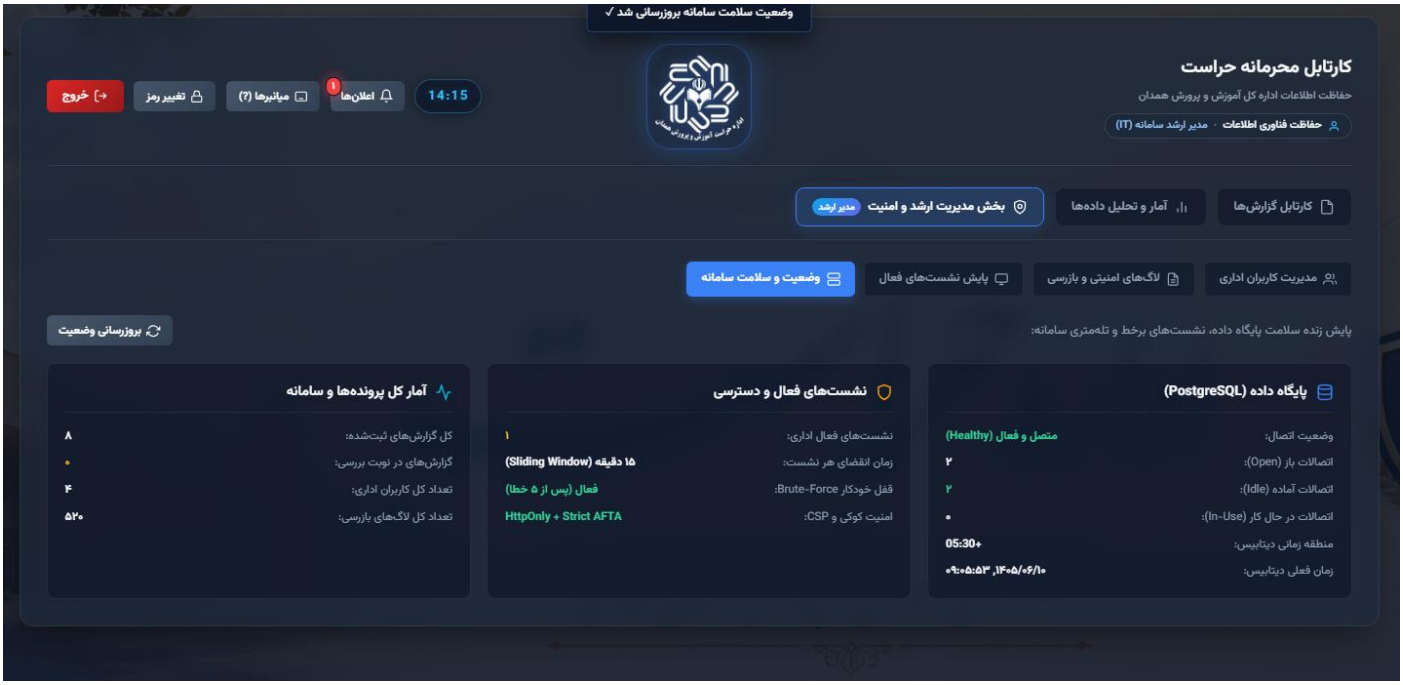
این بخش منحصرا در اختیار مدیر ارشد[۲۰] قرار دارد و امکانات امنیتی زیر را فراهم می سازد:





[۲۰] Superuser





مدیریت حساب های کاربری: ایجاد کاربر اداری جدید با تعیین نام و نام خانوادگی، نام کاربری و سمت سازمانی. امکان غیرفعال سازی موقت یا حذف دائم حساب کارشناسان فراهم است (حساب مدیر ارشد غیرقابل حذف و مسدودسازی می باشد).

سیاست اعتبار ۳۰ روزه رمز عبور و تغییر اجباری:

- ✓ **رمزهای عبور حداکثر ۳۰ روز اعتبار دارند و بعد از آن منقضی می شوند.**
- ✓ **مدیر ارشد می تواند برای هر کاربر گزینه «الزام به تغییر رمز در ورود بعدی» را فعال کند.**
- ✓ **در صورت انقضا یا الزام، هنگام ورود کارشناس، یک پنجره اجباری باز شده و اجازه دسترسی به کارتابل را تا زمان تعیین رمز عبور جدید و پیچیده نمی دهد.**

پایش نشست های فعال و آنلاین[۲۱]:

مدیر ارشد می تواند تمام نشست های فعال سیستم را همراه با آدرس IP، سیستم عامل و مرورگر کاربر[۲۲]، زمان ورود، آخرین فعالیت و زمان باقی مانده از اعتبار نشست[۲۳] مشاهده کند.

امکان ابطال فوری و قطع دسترسی هر یک از نشست های مشکوک با یک کلیک وجود دارد.

پایش لاگ های بازرسی و نظارتی[۲۴]: مشاهده تمامی رویدادها (ورود، خروج، مشاهده پرونده، تغییر رمز، ثبت پاسخ و تغییر اولویت) همراه با نام کاربر، سمت اداری، کد رهگیری پرونده، آدرس IP و زمان دقیق وقوع.

پیاده سازی سازوکارهای امنیتی و تطابق با الزامات افتا

سامانه ستاد خبری حراست به دلیل دریافت گزارش های حساس و طبقه بندی شده، بر مبنای اصل «دفاع در عمق»[۲۵] طراحی گردیده است. تمهیدات فنی پیاده سازی شده در این فصل به گونه ای است که حتی در صورت دسترسی غیرمجاز فیزیکی به فایل های سرور یا نشت فایل پشتیبان پایگاه داده، اطلاعات به هیچ وجه به صورت خام قابل خواندن و سو استفاده نباشد.

۴.۱ رمزنگاری متقارن احراز اصالت شده با AES-256-GCM

تمام اطلاعات هویتی گزارش دهندگان، متن گزارش های واصله، یادداشت های محرمانه کارشناسان، پیام های تکمیلی و فایل های پیوست با الگوریتم متقارن پیشرفته [26] AES-256-GCM رمزگذاری می شوند.

---

[۲۱] Active Sessions Monitor

[۲۲] User-Agent

[۲۳] TTL

[۲۴] Audit Logs Viewer

[۲۵] Defense in Depth

[26] حالت شمارنده گالوا

مزیت الگوریتم GCM نسبت به CBC: بر خلاف حالت های قدیمی مثل CBC که فقط داده را رمز می کنند، حالت GCM همزمان عملیات رمزگذاری[۲۷] و اصالت سنجی داده[۲۸] را انجام می دهد. اگر حتی یک بیت از داده رمز شده در دیتابیس یا روی دیسک دستکاری شود، سرور بلافاصله متوجه عدم تطابق تگ اصالت شده و خطای امنیتی صادر می کند.

تولید بردار مقدار دهی اولیه یکتا[۲۹]: برای هر بار رمزنگاری، یک رشته تصادفی دوازده بایتی کاملا یکتا از ماژول امن سیستم عامل تولید می شود تا رمزنگاری دو متن کاملا مشابه، خروجی های کاملا متفاوتی تولید کند و امکان حدس الگوها سلب گردد.

رمزنگاری اختصاصی بایت های فایل پیوست: فایل های چندرسانه ای و اسناد، قبل از نوشتن روی هارد دیسک سرور، به صورت بایت به بایت رمز شده و یک هدر استاندارد ۵ بایتی[۳۰] به اول آنها الصاق می شود. حتی اگر شخصی مستقیما به پوشه secure_uploads سرور دسترسی پیدا کند، با فایل های باینری کاملا نامفهوم مواجه خواهد شد.

پوشه secure_uploads همان مسیر نگهداری فایل های بارگزاری شده مراجعین است که کاملا در محیط سرور محافظت شده می باشد و همچنین فایل های داخل آن نیز رمز گذاری شده اند تا در صورت نفوذ و نشت اطلاعات نیز به صورت عادی نتوان آنهارا باز کرد.

۴.۲ اعتبارسنجی پیچیدگی و هش سازی کلمات عبور با الگوریتم Argon2id

برای حفاظت از گذرواژه های مدیران و کارشناسان در برابر حملات کرک با کارت های گرافیک قدرتمند[۳۱]، از الگوریتم برنده مسابقه بین المللی توابع هش رمز عبور، یعنی Argon2id استفاده شده است.

---

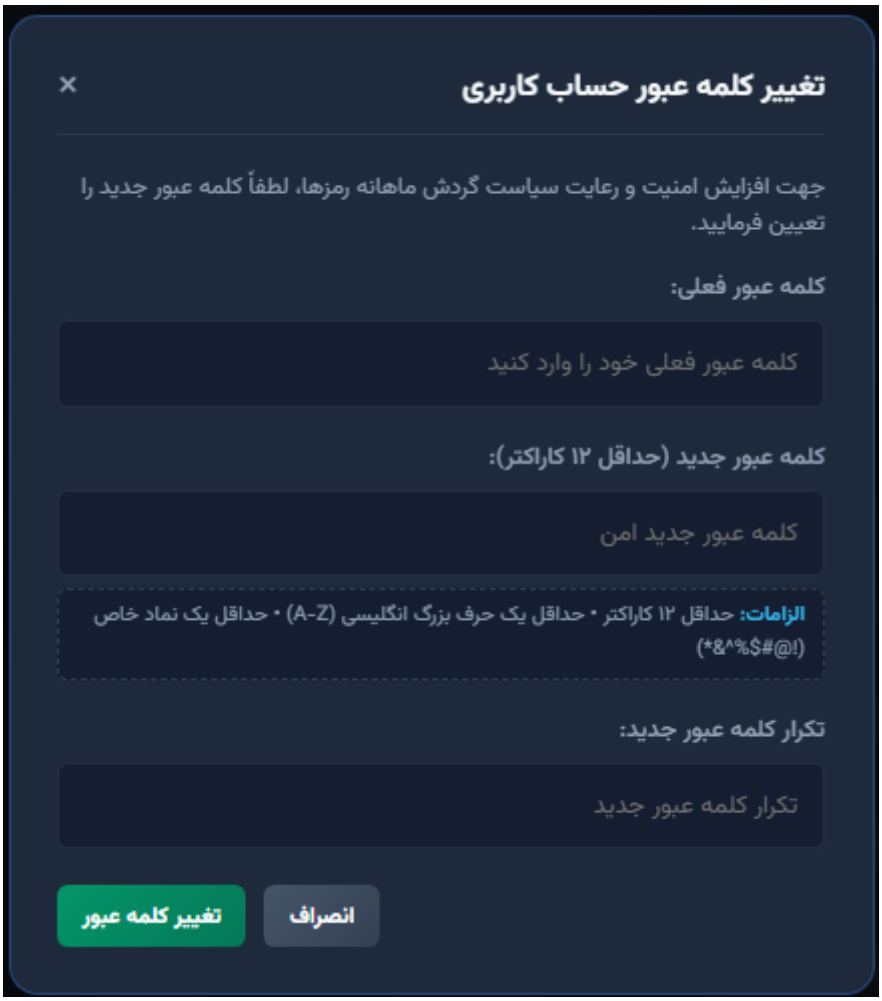
[۲۷] Confidentiality

[۲۸] Integrity / Authenticity

[۲۹] Nonce

[۳۰] HENC\x01

[۳۱] GPU Cracking



پارامترهای فنی الگوریتم Argon2id:

- ✓ **میزان حافظه مصرفی : ٦٤ مگابایت حافظه رم برای هر بار بررسی رمز.**
- ✓ **تعداد تکرار : ۱ چرخه پردازشی.**
- ✓ **تعداد نخ های موازی : ٤ نخ پردازشی همزمان.**
- ✓ **طول نمک تصادفی : ١٦ بایت تصادفی منحصر به فرد برای هر رمز.**

این تنظیمات باعث می شود حملات جستجوی فراگیر[۳۲] سخت افزاری از نظر مصرف رم و پردازنده عملا غیرممکن شود.

سیاست سخت گیرانه پیچیدگی رمز عبور[۳۳]:

---

[۳۲] Brute-Force

[۳۳] Password Policy

- ✓ **حداقل طول رمز عبور ۱۲ کاراکتر.**
- ✓ **اجبار به وجود حداقل یک حرف بزرگ انگلیسی (A-Z).**
- ✓ **اجبار به وجود حداقل یک علامت یا نماد خاص (!@#$٪^&*...).**

۴.۳ سیستم تصویر امنیتی (کپچا) محاسباتی بدون حالت

به منظور مقابله با ربات های اینترنتی، حملات منع سرویس[۳۴] و ارسال هرزنامه، یک ماژول کپچای ریاضی بدون نیاز به پایگاه داده و بدون وابستگی پیاده سازی شده است:



- ✓ **تولید تصویر وکتوری SVG در حافظه: معادلات جمع و تفریق ساده به صورت وکتور با المان های نویز، دایره های رنگی پراکنده، چرخش تصادفی کاراکترها و فیلترهای اعوجاجی[۳۵] در لحظه ساخته شده و به صورت Base64 ارسال می شوند.**
- ✓ **امضای امنیتی HMAC-SHA256 (بدون نیاز به ذخیره در دیتابیس): پاسخ معادله به همراه زمان انقضای ۲ دقیقه ای درون یک رشته json قرار گرفته و با کلید مخفی سرور امضای دیجیتال می شود.**
- ✓ **مکانیزم ضد بازپخش[۳۶]: پس از یک بار حل صحیح کپچا، امضای آن در جدول حافظه ثبت شده و امکان استفاده مجدد از همان کپچا سلب می گردد. یک روال پس زمینه نیز کپچاهای منقضی شده را هر ۲ دقیقه یک بار از رم پاک می کند.**

۴.۴ مدیریت نشست های کاری، کنترل نرخ درخواست و قفل حساب

پروتکل های سخت گیرانه ای برای کنترل دسترسی کارشناسان و مراجعان تعبیه شده است:

---

[۳۴] DoS

[۳۵] feTurbulence

[۳۶] Replay Attack Prevention

نشست تک کاربره همزمان[۳۷]: هر حساب کاربری در لحظه فقط می تواند روی یک مرورگر باز باشد. اگر کاربری در سیستم وارد شود و سپس از دستگاه دیگری با همان حساب لاگین کند، نشست قبلی فورا با برچسب CONCURRENT_LOGIN **لغو شده و در مرورگر اول هشدار قرمز رنگ خروج فوری نشان داده می شود.**



پالس سلامت بلادرنگ[۳۸]: مرورگر ادمین هر ۸ ثانیه یک بار وضعیت اعتبار نشست را از سرور استعلام می کند تا به محض ابطال نشست، صفحه قفل شود.

تایمر انقضای نشست کاری (۱۵ دقیقه شناور): نشست کاری کارشناسان در صورت عدم فعالیت پس از ۱۵ دقیقه منقضی می گردد. با انجام هر اقدام معتبر، تایمر به صورت خودکار بازنشانی می شود. در ۶۰ ثانیه پایانی، پنجره هشدار به کارشناس نشان داده خواهد شد.

قفل خودکار حساب در برابر حدس رمز[۳۹]: در صورت پنج بار تلاش ناموفق پیاپی در ورود به یک حساب، آن حساب به مدت ۱۵ دقیقه مسدود شده و امکان لاگین نخواهد داشت.

محدود سازی نرخ درخواست[۴۰]: بر اساس الگوریتم مخزن توکن[۴۱]، درخواست های ورودی کنترل می شوند:

---

[۳۷] Single-Session Enforcement

[۳۸] Heartbeat Polling

[۳۹] Account Lockout

[۴۰] IP Rate Limiting

[۴۱] Token Bucket

- ✓ مسیر ورود ادمین: حداکثر ۵ درخواست در دقیقه.
- ✓ مسیر ثبت گزارش و پیام تکمیلی: حداکثر ۲ درخواست در دقیقه.
- ✓ مسیر استعلام و رهگیری: حداکثر ۳۰ درخواست در دقیقه.
- ✓ مسیر دریافت کپچا: حداکثر ۶۰ درخواست در دقیقه.

۴.۵ لاگ های بازرسی تغییرناپذیر پایگاه داده (قاعده WORM[۴۲]) و هدرهای امنیتی

یکی از مهم ترین الزامات ابلاغی مرکز مدیریت راهبردی افتا، غیرقابل دستکاری بودن لاگ های نظارتی است. محرک های بازدارنده پایگاه داده[۴۳]: در دیتابیس PostgreSQL، تریگرهای سطح سیستمی پیاده سازی شده که اجرای هرگونه دستور ویرایش[۴۴]، حذف رکورد[۴۵] یا تخلیه کامل جدول[۴۶] را روی جدول audit_logs مسدود می کند و خطای سیستمی صادر می نماید.

کوکی های امن و هدر های سخت گیرانه وب: کوکی نشست های اداری با ویژگی های HttpOnly (غیرقابل دسترسی برای کدهای جاوا اسکریپت و ضد حملات XSS) و SameSite=Lax تنظیم می شوند.

ساختار جداول پایگاه داده و روابط موجودیت ها

پایگاه داده سامانه در محیط PostgreSQL پیاده سازی شده و ساختار آن بر اساس رعایت اصل تفکیک داده ها، بهینه سازی سرعت با ایندکس گذاری های کاربردی و اعمال قیدهای یکپارچگی ارجاعی[۴۷] با قابلیت حذف آبشاری[۴۸] طراحی شده است.

---

[۴۲] Write Once, Read Many

[۴۳] WORM Triggers

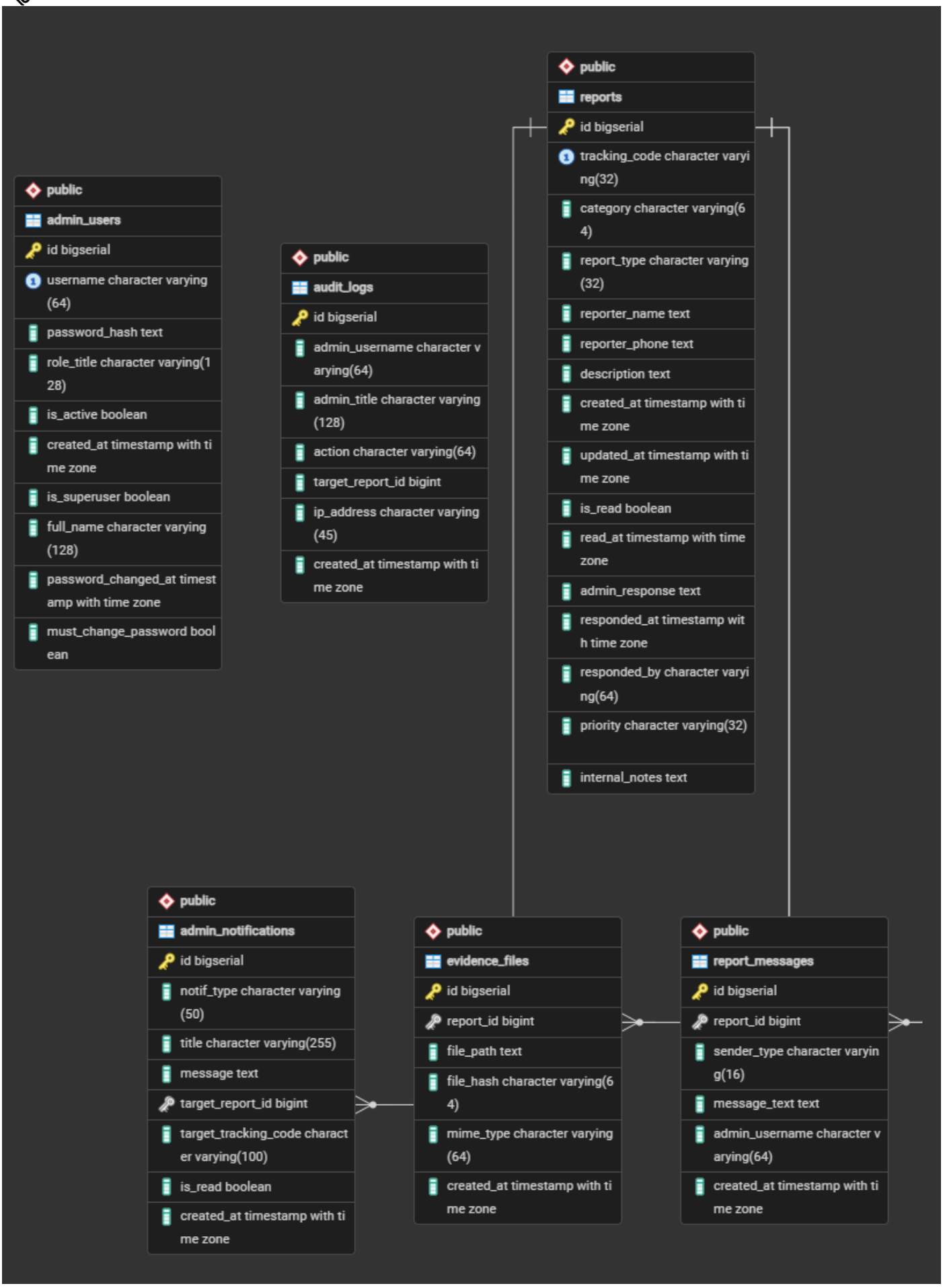
[۴۴] UPDATE

[۴۵] DELETE

[۴۶] TRUNCATE

[۴۷] Foreign Keys

[۴۸] ON DELETE CASCADE


public
admin_users
id bigserial
username character varying (64)
password_hash text
role_title character varying(128)
is_active boolean
created_at timestamp with time zone
is_superuser boolean
full_name character varying (128)
password_changed_at timestamp with time zone
must_change_password boolean
public
audit_logs
id bigserial
admin_username character varying(64)
admin_title character varying (128)
action character varying(64)
target_report_id bigint
ip_address character varying (45)
created_at timestamp with time zone
public
reports
id bigserial
tracking_code character varying(32)
category character varying(64)
report_type character varying (32)
reporter_name text
reporter_phone text
description text
created_at timestamp with time zone
updated_at timestamp with time zone
is_read boolean
read_at timestamp with time zone
admin_response text
responded_at timestamp with time zone
responded_by character varying(64)
priority character varying(32)
internal_notes text
public
admin_notifications
id bigserial
notif_type character varying (50)
title character varying(255)
message text
target_report_id bigint
target_tracking_code character varying(100)
is_read boolean
created_at timestamp with time zone
public
evidence_files
id bigserial
report_id bigint
file_path text
file_hash character varying(64)
mime_type character varying (64)
created_at timestamp with time zone
public
report_messages
id bigserial
report_id bigint
sender_type character varying(16)
message_text text
admin_username character varying(64)
created_at timestamp with time zone

راهنمای راه اندازی، متغیرهای محیطی و استقرار سیستمی

سامانه به دلیل کامپایل شدن به یک فایل اجرایی واحد در زبان Go، نیازمندی های اجرایی بسیار سبکی دارد و به راحتی روی سرورهای لینوکسی (مانند Ubuntu Server یا RHEL) یا سرورهای ویندوزی مستقر می شود.

۶.۱ پیش نیازهای سخت افزاری و نرم افزاری سرور

حداقل سخت افزار پیشنهادی: پردازنده ۲ هسته ای، ۲ گیگابایت حافظه رم، ۲۰ گیگابایت فضای ذخیره سازی پرسرعت SSD.

سیستم عامل پیشنهادی: Ubuntu Server 22.04 LTS / 24.04 LTS یا Windows Server 2019/2022.

پایگاه داده: PostgreSQL نگارش ۱۴ یا بالاتر.

محیط پایتون (جهت صدور فایل Word): پایتون نگارش ۳.۹ به همراه کتابخانه python-docx.

۶.۲ جدول متغیرهای محیطی سیستم[۴۹]

پیکربندی امنیتی سامانه به منظور جلوگیری از افشای کلیدها در کد برنامه، از طریق متغیرهای محیطی سرور تامین می شود:

[۴۹] Environment Variables

نام متغیر محیطی	الزام	مقدار نمونه /پیش فرض	شرح تنظیمات
HERASAT_AES_KEY	**الزامی**	رشته ۳۲ بایتی	کلید اصلی ۲۵۶ بیتی جهت رمزنگاری تمام داده ها و فایل ها
HERASAT_DB_CONN	**الزامی**	host=۱۲۷.۰.۰.۱ port=۵۴۳۲ user=...	رشته اتصال امن به پایگاه داده PostgreSQL
HERASAT_PORT	اختیاری	۸۰۸۰	پورت گوش دادن به درخواست های وب سرور
HERASAT_BIND_ADDR	اختیاری	۰.۰.۰.۰:۸۰۸۰	آدرس و پورت اتصال شبکه ای سرور
HERASAT_COOKIE_SECURE	اختیاری	true یا false	الزام استفاده از کوکی های فقط HTTPS در شبکه
HERASAT_TLS_CERT	اختیاری	/path/to/cert.pem	مسیر فایل گواهی امنیتی SSL/TLS جهت فعال سازی HTTPS
HERASAT_TLS_KEY	اختیاری	/path/to/key.pem	مسیر فایل کلید خصوصی گواهی SSL/TLS

۶.۳ مراحل گام به گام استقرار و راه اندازی در لینوکس

۱. آماده سازی پایگاه داده و ساخت ساختار جداول:

ابتدا کاربر و پایگاه داده در PostgreSQL ساخته شده و اسکریپت schema.sql اجرا می گردد:

```
$ db.bash
$ db.bash
1   sudo -u postgres psql
2   CREATE DATABASE herasat_db;
3   CREATE USER herasat_user WITH ENCRYPTED PASSWORD 'password';
4   GRANT ALL PRIVILEGES ON DATABASE herasat_db TO herasat_user;
5   \c herasat_db
6   \i /path/to/schema.sql
7   \q
```

۲. کامپایل کردن پروژه Go:

با استفاده از کامپایلر Go، فایل اجرایی نهایی سرور ساخته می شود:

```
$ compile.bash
1   go mod tidy
2   go build -ldflags="-s -w" -o herasat-server .
```

۳. تنظیم سرویس سیستمی لینوکس[۵۰]:

جهت اجرای خودکار برنامه در پس زمینه و بالا آمدن پس از ریستارت سرور، فایل سرویس /etc/systemd/system/herasat.service ایجاد می شود:

```
linux.toml
1   [Unit]
2   Description=Herasat Secure Newsroom Portal Service
3   After=network.target postgresql.service
4
5   [Service]
6   Type=simple
7   User=herasat
8   WorkingDirectory=/opt/herasat-portal
9   ExecStart=/opt/herasat-portal/herasat-server
10  Restart=always
11  RestartSec=5s
12
13  Environment="HERASAT_AES_KEY=Your32ByteSecretKeyForAESGCM!!"
14  Environment="HERASAT_DB_CONN=host=127.0.0.1 port=5432 user=herasat_user password=herasat1405@ dbname=herasat_db sslmode=disable"
15  Environment="HERASAT_PORT=8080"
16  Environment="HERASAT_COOKIE_SECURE=false"
17
18  LimitNOFILE=65535
19
20  [Install]
21  WantedBy=multi-user.target
```

٤. فعال سازی و اجرای سرویس:

```
$ run.bash
1   sudo systemctl daemon-reload
2   sudo systemctl enable herasat.service
3   sudo systemctl start herasat.service
4   sudo systemctl status herasat.service
```

۵۰ Systemd Service

۶.۴ دستورالعمل تهیه پشتیبان و نگهداری دوره‌ای[۵۱]

- ✓ **پشتیبان گیری منظم از دیتابیس: با اجرای دستور** pg_dump -U herasat_user herasat_db > backup.sql **به صورت خودکار در پایان هر روز اداری.**
- ✓ **پشتیبان گیری از پوشه فایل های رمزشده: تهیه نسخه پشتیبان از دایرکتوری** secure_uploads. **(توجه: بدون در دست داشتن مقدار** HERASAT_AES_KEY**، فایل های بک آپ روی هیچ سیستم دیگری باز نخواهند شد، لذا نگهداری این کلید در محل امن الزامی است).**
- ✓ **پایش مداوم منابع سرور: کارشناس فناوری اطلاعات می تواند در پنل مدیریت، زبانه «وضعیت و سلامت سامانه» را باز کرده و تعداد اتصالات باز پایگاه داده، مصرف منابع و وضعیت اتصال دیتابیس را به شکل زنده بررسی نماید.**

---

[۵۱] Backup & Maintenance